

Playbook de Malware

Divier Jácamo Álvarez

Cetav La Libertad

Rol: Analista L1

Fecha: miércoles 25/02/26

Playbook de detención de Malware

1. Introducción

La complejidad del malware ha progresado desde amenazas simples basadas en firmas hasta variantes polimórficas y ataques que no utilizan archivos, aprovechando herramientas legítimas del sistema. Por lo tanto, la detección ya no puede apoyarse únicamente en soluciones antivirus convencionales, sino que debe formar parte de una estructura de monitoreo continuo y análisis de comportamiento.

La etapa de detección y análisis es crucial para mitigar el impacto organizacional que puede resultar de incidentes de seguridad así, este manual establece procedimientos técnicos, organizativos y estratégicos para la identificación sistemática de actividades maliciosas.

2. Marco Conceptual

Definición de Malware

El término malware se refiere a cualquier tipo de software que busca infiltrarse, dañar o interrumpir sistemas sin la aprobación del usuario. Esto incluye virus, gusanos, ransomware, troyanos y spyware.

Enfoque Basado en Riesgo

Este manual emplea un enfoque fundamentado en el riesgo, tomando en cuenta:

El valor del activo comprometido.

La probabilidad de explotación.

El impacto en operaciones, finanzas y reputación.

Este método se alinea con los principios de gestión de incidentes que se encuentran en la norma ISO/IEC 27035.

3. Objetivos

Objetivo General

Crear un procedimiento integral para la detección de malware que permita reconocer, analizar y escalar eventos sospechosos de manera efectiva y documentada.

Objetivos Específicos

Incorporar inteligencia de amenazas en el monitoreo continuo.

Disminuir el tiempo promedio de detección.

Estandarizar criterios de gravedad.

Fortalecer la capacidad analítica del SOC.

4. Alcance

Este manual aplica a:

Infraestructura local.

Servicios en la nube, tanto públicos como privados.

Dispositivos de usuario final.

Plataformas críticas para el negocio.

5. Arquitectura de Detección

La detección se basa en una estructura de múltiples capas que incluye:

Capa de Endpoint: Soluciones EDR con monitoreo basado en comportamiento.

Capa de Red: IDS/IPS y análisis de tráfico.

Capa de Registro Centralizado: Plataforma SIEM para la correlación de datos.

Capa de Inteligencia de Amenazas: Integración de IoC externos y tácticas documentadas en

MITRE ATT&CK.

6. Procedimiento Operativo

Fase 1: Monitoreo Continuo

Recolección automatizada de registros.

Correlación de eventos identificados como sospechosos.

Generación de alertas ante comportamientos anómalos.

Fase 2: Análisis Inicial

Responsable: Analista SOC Nivel 1

Actividades:

Confirmar la fuente de la alerta.

Verificar el hash del archivo.

Evaluar la reputación en fuentes de OSINT.

Corroborar si es un falso positivo.

Fase 3: Análisis Avanzado

Responsable: Analista SOC Nivel 2

Actividades:

Análisis de comportamiento en un entorno de sandbox.

Identificación de métodos de persistencia.

Mapeo de tácticas y técnicas usando MITRE ATT&CK.

Evaluación del movimiento lateral.

Fase 4: clasificación y escalamiento

Nivel	Descripción
Bajo	Actividad sospechosa sin confirmación de ejecución maliciosa
Medio	Malware detectado sin programa
Alto	Evidencia de persistencia o comunicación
Critico	Impacto en activos criticos

7. Indicadores de Detección

Técnicos

Alteraciones en las claves del registro.

Generación de procesos anómalos.

Tráfico cifrado destinado a dominios sospechosos.

Conductuales

Escalamiento no autorizado de privilegios.

Uso inapropiado de herramientas administrativas.

8. Métricas y Evaluación

La eficacia del manual será medida mediante:

Tiempo promedio de detección.

Tiempo promedio de análisis.

Porcentaje de falsos positivos.

Nivel de cobertura de técnicas del marco MITRE ATT&CK.

9. Gestión Documental

Cada evento confirmado debe incluir:

Identificador único del incidente.

Cronología detallada.

Evidencias recogidas.

Técnicas relacionadas según MITRE ATT&CK.

Recomendaciones de prevención.

10. Mejora Continua

La actualización de este manual debe llevarse a cabo anualmente o después de incidentes

significativos, incluyendo:

Nuevos patrones de ataque.

Lecciones aprendidas.

Actualizaciones normativas.

Flujo de Detención de malware

1. Introducción

Los eventos del sistema son registros organizados generados automáticamente por sistemas operativos, aplicaciones y dispositivos de infraestructura. Estos registros son la principal fuente de indicios para la identificación de anomalías y actividades relacionadas con malware.

Un flujo de detección basado en eventos permite estructurar la vigilancia, minimizar falsos positivos y estandarizar criterios analíticos dentro de un Centro de Operaciones de Seguridad.

2. Objetivo

Debería elaborar un flujo operativo para la detección de malware basado en el análisis y la correlación de eventos del sistema, con el fin de detectar actividades maliciosas en las primeras etapas del ciclo de ataque.

3. Fuentes de Eventos

El flujo incluye la integración de diversas fuentes de registros:

Eventos del sistema operativo:

Creación y finalización de procesos.

Alteraciones en los privilegios de usuario.

Modificaciones en el registro.

Eventos de seguridad:

Intentos no exitosos de autenticación.

Establecimiento de cuentas.

Alteraciones en políticas de seguridad.

Eventos de red:

Conexiones salientes inusuales.

Comunicación con dominios sospechosos.

Eventos de aplicaciones críticas:

Accesos no autorizados.

Ejecución de scripts o macros.

4. Arquitectura del Flujo de Detección

El flujo se sostiene sobre una arquitectura centralizada que incluye:

Recolección de logs mediante agentes.

Normalización de eventos en una plataforma SIEM.

Correlación basada en normas y comportamientos.

Enriquecimiento utilizando inteligencia sobre amenazas.

Clasificación y escalamiento del incidente.

5. Flujo Operativo de Detección

Fase 1: Recolección

Captura automática de eventos en tiempo real.

Transmisión segura al repositorio central.

Comprobación de la integridad del log.

Fase 2: Normalización y Filtrado

Conversión a un formato estándar.

Eliminación de eventos irrelevantes.

Priorización de eventos críticos.

Fase 3: Correlación

Se utilizan reglas predefinidas tales como:

Regla 1: Varios intentos fallidos de autenticación más la creación de un proceso inusual.

Regla 2: Ejecución de PowerShell más conexión saliente a una IP externa no categorizada.

Regla 3: Alteración de claves de persistencia más elevación de privilegios.

Fase 4: Generación de Alerta

Cuando la correlación sobrepasa un límite de riesgo determinado:

Se genera una alerta automática.

Se asigna un ticket en la plataforma de gestión.

Se categoriza la severidad de manera preliminar.

Fase 5: Análisis Inicial

Responsable: Analista SOC Nivel 1

Validación de la coherencia del evento.

Detección de posibles falsos positivos.

Revisión contextual del activo implicado.

Análisis Avanzado y Escalamiento

Responsable: Analista SOC Nivel 2

Reconstrucción de la línea temporal del ataque.

Identificación de indicadores de compromiso.

Mapeo técnico según MITRE ATT&CK.

6. Criterio de Severidad

Nivel	Descripción	Acción
Bajo	Evento aislado sin correlación adicional	Monitoreo
Medio	Evento correlacionado con comportamiento anómalo	Análisis extendido
Alto	Evidencia de ejecución maliciosa	Escalamiento Inmediato
Critico	Compromiso confirmado com impacto operacional	Activación IR

7. Métricas de Evaluación

Tiempo medio de detección.

Tiempo medio de análisis.

Tasa de correlaciones efectivas.

Cobertura de técnicas según MITRE ATT&CK.

8. Control y Mejora Continua

El flujo debe revisarse de manera regular teniendo en cuenta:

Actualizaciones sobre amenazas emergentes.

Modificaciones en la infraestructura tecnológica.

Nuevas técnicas documentadas por MITRE ATT&CK.

Recomendaciones del National Institute of Standards and Technology sobre monitoreo

continuo.

Un flujo de detección basado en eventos del sistema refuerza la capacidad analítica del SOC al organizar la supervisión de registros críticos, permitiendo correlaciones contextualizadas la integración con estándares internacionales y marcos de conocimiento establecidos otorga rigor metodológico y consistencia operativa la detección anticipada, basada en un análisis sistemático de eventos, disminuye notablemente la posibilidad de escalamiento del impacto en la organización.

Documentación de detención de Malware

1. Propósito

Establecer un procedimiento estandarizado para la documentación exhaustiva de los acontecimientos, análisis y decisiones generadas durante la identificación de malware basada en eventos del sistema.

2. Alcance

El procedimiento se aplica a:

Alertas emitidas por el SIEM.

Eventos relacionados con actividades posiblemente maliciosas.

Análisis realizados por los analistas SOC de Nivel 1 y Nivel 2.

Escalamientos realizados al equipo de respuesta ante incidentes.

3. Principios de Documentación

La documentación debe adherirse a los siguientes principios:

Trazabilidad: Cada evento ha de poder ser reconstruido en orden cronológico.

Integridad: Los registros no deben ser modificados sin un control formal.

Claridad técnica: La redacción ha de ser objetiva y susceptible de verificación.

Estandarización: Uso de formatos coherentes y plantillas oficiales.

Confidencialidad: Clasificación de la información de acuerdo a su criticidad.

4. Elementos Obligatorios del Registro

Cada alerta o evento verificado debe documentarse incluyendo:

Identificación General

ID único del incidente.

Fecha y hora de detección.

Fuente del evento.

Activo afectado.

Descripción Técnica

Tipo de evento detectado.

Reglas de correlación que fueron activadas.

Hashes, direcciones IP, dominios u otros IoC.

Técnica asociada según MITRE ATT&CK.

Análisis Realizado

Validaciones llevadas a cabo.

Evidencias recopiladas.

Herramientas empleadas.

Determinación de falso positivo o incidente confirmado.

Clasificación y Severidad

Nivel de criticidad.

Justificación técnica de la clasificación.

Decisiones y Acciones

Escalamiento realizado.

Recomendaciones técnicas.

Notificaciones efectuadas.

6. Flujo de Documentación

Registro Inicial

El Analista SOC Nivel 1 debe:

Crear el ticket en el sistema de gestión.

Registrar una descripción preliminar.

Adjuntar evidencias iniciales.

Actualización del Análisis

El Analista SOC Nivel 2 debe:

Ampliar la cronología del evento.

Incorporar IoC adicionales.

Documentar la alineación táctica conforme a MITRE ATT&CK.

Cierre del Registro

El Coordinador SOC debe:

Validar la completitud del expediente.

Confirmar la clasificación correcta.

Autorizar el cierre formal del incidente.

7. Control de Calidad

Se implementarán los siguientes mecanismos:

Auditoría mensual de los tickets cerrados.

Revisión cruzada entre analistas.

Validación de la integridad de los logs almacenados.

Evaluación del cumplimiento conforme a ISO/IEC 27035.

8. Retención y Resguardo de Registros

Los registros deben conservarse por un periodo mínimo establecido por la política organizacional.

El almacenamiento deberá garantizar cifrado y control de acceso.

Se realizará un respaldo periódico en repositorios seguros.

9. Indicadores de Desempeño de la Documentación

Porcentaje de incidentes documentados de manera completa.

Tiempo promedio de cierre documental.

Número de hallazgos en auditorías internas.

Nivel de cobertura de técnicas alineadas según MITRE ATT&CK.

10. Mejora Continua

La documentación debe ser revisada periódicamente teniendo en cuenta:

Nuevas técnicas emergentes reportadas en MITRE ATT&CK.

Recomendaciones actualizadas del National Institute of Standards and Technology.

Resultados de auditorías internas o externas.

Conclusión

La documentación estructurada del proceso de detección de malware no solo asegura evidencia técnica y cumplimiento normativo, sino que también refuerza la capacidad analítica y estratégica del SOC la alineación con estándares internacionales fomenta una consistencia metodológica, transparencia operativa y mejora continua en la gestión de incidentes basados en eventos del sistema.

Referencias

National Institute of Standards and Technology. (2012). *Computer Security Incident Handling Guide (SP 800-61 Rev. 2)*. Recuperado de [Computer Security Incident Handling Guide \(NIST SP 800-61 Rev. 2, PDF\)](#)

International Organization for Standardization. (2023). *ISO/IEC 27035-1:2023 — Information Security Incident Management — Principles and Process*. Disponible: [ISO/IEC 27035-1:2023 \(preview PDF\)](#)

MITRE Corporation. (2025). *MITRE ATT&CK®: A knowledge base for adversary tactics and techniques*. Recuperado de [MITRE ATT&CK \(oficial\)](#)

Division Cero Docs. (2025). *Correlación de eventos y SIEM*. Recuperado de [Correlación de eventos y SIEM — referencias al NIST y MITRE ATT&CK](#)